Klausel-Prüfliste

Betrieb: Muster Elektrotechnik e.U. Datum: 23. Oktober 2026

Kunden, die unter die NIS-2-Richtlinie fallen, müssen die Sicherheit der Lieferkette regeln, einschließlich der sicherheitsbezogenen Aspekte ihrer Beziehungen zu Lieferanten (Art. 21 Abs. 2 Buchst. d). Für Cloud- und Rechenzentrumsanbieter, Managed-Service- und Managed-Security-Anbieter, Online-Marktplätze und weitere digitale Anbieter hat die Kommission acht Vertragsinhalte aufgezählt (Durchführungsverordnung (EU) 2024/2690, Anhang, Nr. 5.1.4); viele andere Kunden übernehmen sie. Finanzkunden unter DORA müssen neun Inhalte in jeden Vertrag über IKT-Dienstleistungen aufnehmen und sechs weitere, wenn die Leistung eine kritische oder wichtige Funktion unterstützt. Diese Liste nennt jede Klausel, woher sie kommt, was sie bedeutet, was ein Betrieb Ihrer Größe zusagen kann, was zu verhandeln ist, und Ihre Lage heute. Die Ratschläge sind Auslegung, keine Rechtsberatung; einen Vertrag, auf den es ankommt, lassen Sie vor der Unterschrift anwaltlich prüfen.

Teil A · Klauseln, die jeder Kunde bringen kann

Nr.	Klausel	Herkunft	Was sie bedeutet	Zusagen und verhandeln	Ihre Lage
K1	Cybersicherheitsanforderungen an den Lieferanten	Durchführungsverordnung (EU) 2024/2690, Anhang, Nr. 5.1.4 Buchst. a	Der Kunde schreibt Maßnahmen vor, die Sie einhalten müssen, manchmal „Stand der Technik“ oder eine Norm.	Die Maßnahmen Ihrer Selbstauskunft und die Termine Ihres Maßnahmenplans zusagen; „Stand der Technik“ durch einen Verweis auf die Selbstauskunft ersetzen; keine Norm, die Sie nicht haben. Gibt der Kunde Nr. 11.6.2 Buchst. c der Durchführungsverordnung weiter (regelmäßiger Passwortwechsel), vereinbaren, dass Passwort-Manager mit langen Einzelpasswörtern und Multi-Faktor-Authentifizierung ihn ersetzen, oder einen jährlichen Wechsel für Administratorkonten zusagen.	B1: Teilweise: Ein paar Regeln gibt es, nicht als ein Dokument · geplant bis 21. Jänner 2027 · C2: Vorhanden: Authenticator-App · D1: Teilweise: täglich auf das NAS im Büro, keine Offline-Kopie · geplant bis 22. November 2026
K2	Sensibilisierung, Fähigkeiten, Schulung, Zertifizierungen Ihrer Beschäftigten	Durchführungsverordnung (EU) 2024/2690, Anhang, Nr. 5.1.4 Buchst. b	Ihre Beschäftigten müssen eingewiesen sein; manchmal werden Zertifizierungen verlangt.	Eine jährliche Einweisung mit Nachweis zusagen; Zertifizierungen je Person wegverhandeln.	G1: Noch nicht · geplant bis 21. Jänner 2027
K3	Überprüfung des Hintergrunds Ihrer Beschäftigten	Durchführungsverordnung (EU) 2024/2690, Anhang, Nr. 5.1.4 Buchst. c	Prüfungen der Personen, die für den Kunden arbeiten.	Identitätsprüfung bei Einstellung und schriftliche Vertraulichkeit zusagen; Hintergrundprüfungen nur, soweit nationales Recht es erlaubt, auf Wunsch und Kosten des Kunden.	G2: Vorhanden

Nr.	Klausel	Herkunft	Was sie bedeutet	Zusagen und verhandeln	Ihre Lage
K4	Meldung von Vorfällen ohne unangemessene Verzögerung	Durchführungsverordnung (EU) 2024/2690, Anhang, Nr. 5.1.4 Buchst. d	Sie müssen Vorfälle melden, die die Systeme des Kunden gefährden.	Die Frist zusagen, die Sie auch nachts und im Urlaub halten; Weg und Person benennen; Stundenfristen ab Ihrer Kenntnis verhandeln.	F1: Innerhalb von 24 Stunden nach Kenntnis, telefonisch, durch die Leitung oder ihre Vertretung
K5	Prüfrecht oder Recht auf Prüfberichte	Durchführungsverordnung (EU) 2024/2690, Anhang, Nr. 5.1.4 Buchst. e	Der Kunde darf Sie prüfen oder will Berichte.	Zusagen: Nachweisliste und Dokumente auf Anfrage, Selbstauskunft jährlich, schriftliche Antworten; Prüfungen vor Ort auf einmal im Jahr, mit Ankündigung und auf Kosten der prüfenden Seite verhandeln.	B3: Keine
K6	Behandlung von Schwachstellen	Durchführungsverordnung (EU) 2024/2690, Anhang, Nr. 5.1.4 Buchst. f	Sie müssen Schwachstellen in dem beheben, was Sie liefern.	Software- und Gerätelieferanten: Kontakt und Frist zusagen. Wer vernetzte Geräte einbaut oder Fernzugriff hat: Weitergabe der Herstellerupdates und Meldung bekannter Schwachstellen ohne unangemessene Verzögerung zusagen. Alle anderen: „nicht anwendbar, wir liefern und installieren keine Software und keine vernetzten Geräte“.	E4: Nicht anwendbar: Wir liefern keine Software und keine Geräte
K7	Unterauftragnehmer und Anforderungen an sie	Durchführungsverordnung (EU) 2024/2690, Anhang, Nr. 5.1.4 Buchst. g	Der Kunde will Ihre Unterauftragnehmer kennen, genehmigen und Anforderungen an sie weitergeben.	Dienstleisterliste, Information vor einem Wechsel und Weitergabe, soweit die Bedingungen des Anbieters es erlauben, zusagen; Genehmigungsrechte zu Informationsrechten verhandeln.	H1: Teilweise: bekannt, nicht als Liste · geplant bis 21. Jänner 2027 · H3: Noch nicht · geplant bis 21. April 2027
K8	Pflichten bei Vertragsende: Rückgabe und Vernichtung von Informationen	Durchführungsverordnung (EU) 2024/2690, Anhang, Nr. 5.1.4 Buchst. h	Bei Beendigung geben Sie zurück oder löschen, was Sie erhalten haben.	Rückgabe oder Löschung mit schriftlicher Bestätigung innerhalb einer vereinbarten Frist zusagen.	I1: Vorhanden
K9	Verzeichniseintrag: eine Kontaktstelle für Sicherheit	Durchführungsverordnung (EU) 2024/2690, Anhang, Nr. 5.2	Der Kunde führt ein Verzeichnis seiner Lieferanten mit Kontaktstellen.	Zusagen: verantwortliche Person und Vertretung mit Telefon und E-Mail benennen.	A4: Inhaber oder Geschäftsführung, +43 660 000 00 01 (Beispiel), buero@muster.at; Vertretung: Büroleitung
K10	Auftragsverarbeitungsvertrag	DSGVO, Art. 28 Abs. 3	Wo Sie personenbezogene Daten im Auftrag des Kunden verarbeiten, ist ein Vertrag mit den Inhalten des Art. 28 Abs. 3 Pflicht.	Den Standardvertrag des Kunden zusagen; prüfen, dass Unterauftragsverarbeiter und Löschung zu Ihrer Dienstleisterliste passen.	H2: Teilweise · geplant bis 21. Jänner 2027
K11	Haftung, Vertragsstrafen, Versicherungsnachweis	Keine Rechtsgrundlage; in Verträgen üblich	Haftungsgrenzen, Vertragsstrafen, Cyberversicherung als Bedingung.	Eine Obergrenze verhandeln, Folgeschäden ausschließen, keine Strafe für eine in gutem Glauben verspätete Meldung; die Police zeigen, wenn es eine gibt, keine versprechen, die es nicht gibt.	B2: Nein

Teil B · Zusätzliche Klauseln von Finanzkunden (DORA)

Nur wenn der Kunde ein Finanzunternehmen ist (Bank, Versicherer, Zahlungs- oder Wertpapierfirma). Fragen Sie schriftlich, ob der Kunde Ihre Leistung als Unterstützung einer kritischen oder wichtigen Funktion einstuft; die sechs Klauseln des Art. 30 Abs. 3 gelten nur dann. Ist das Finanzunternehmen ein Kleinstunternehmen, können die Prüfrechte des Art. 30 Abs. 3 Buchst. e an einen unabhängigen Dritten übertragen werden.

Art. 30 gilt nur für Verträge über IKT-Dienstleistungen. Nach Ihrer Antwort zu A7 erbringen Sie keine IKT-Dienstleistungen; schickt ein Finanzkunde die Klauseln trotzdem, dürfen Sie darauf hinweisen und um Streichung bitten.

Neun Inhalte jedes Vertrags über IKT-Dienstleistungen (Art. 30 Abs. 2)

Zusagen und verhandeln: zusagen, was Ihre Leistung wahrheitsgemäß beschreibt; die Ortsklausel (DORA 2) braucht Ihre Dienstleisterliste; Unterstützung bei Vorfällen (DORA 6) innerhalb Ihrer Meldefrist; Zusammenarbeit mit Behörden ist üblich.

Nr.	Klausel	Herkunft
DORA 1	Beschreibung aller Funktionen und IKT-Dienstleistungen, ob Unterauftragsvergabe zulässig ist und unter welchen Bedingungen	DORA, Art. 30 Abs. 2 Buchst. a
DORA 2	Orte (Regionen oder Länder) der Leistung und der Datenverarbeitung, mit Vorabinformation vor einer Änderung	DORA, Art. 30 Abs. 2 Buchst. b
DORA 3	Verfügbarkeit, Authentizität, Integrität und Vertraulichkeit der Daten, einschließlich personenbezogener Daten	DORA, Art. 30 Abs. 2 Buchst. c
DORA 4	Zugang, Wiederherstellung und Rückgabe der Daten in zugänglichem Format bei Insolvenz, Geschäftsaufgabe oder Vertragsende	DORA, Art. 30 Abs. 2 Buchst. d
DORA 5	Beschreibung der Dienstleistungsgüte, einschließlich Aktualisierungen	DORA, Art. 30 Abs. 2 Buchst. e
DORA 6	Unterstützung bei einem IKT-Vorfall ohne Zusatzkosten oder zu vorab festgelegten Kosten	DORA, Art. 30 Abs. 2 Buchst. f
DORA 7	Volle Zusammenarbeit mit den zuständigen Behörden und Abwicklungsbehörden des Kunden	DORA, Art. 30 Abs. 2 Buchst. g
DORA 8	Kündigungsrechte und Mindestkündigungsfristen	DORA, Art. 30 Abs. 2 Buchst. h
DORA 9	Teilnahme an den Sensibilisierungsprogrammen und Resilienzschulungen des Kunden	DORA, Art. 30 Abs. 2 Buchst. i

Sechs weitere, wenn die Leistung eine kritische oder wichtige Funktion unterstützt (Art. 30 Abs. 3)

Zusagen und verhandeln: nur für Leistungen, die der Kunde als kritisch oder wichtig einstuft. Prüfrechte und Testteilnahme sind die teuren Klauseln: nach Kostenteilung fragen, und den Übergangszeitraum auf das vereinbaren, was Sie leisten können. Ist das Finanzunternehmen ein

Kleinstunternehmen, die Übertragung der Prüfrechte an einen von Ihnen benannten unabhängigen Dritten vorschlagen (Art. 30 Abs. 3 letzter UAbs. DORA).

Nr.	Klausel	Herkunft
DORA 10	Vollständige Beschreibung der Dienstleistungsgüte mit quantitativen und qualitativen Zielen	DORA, Art. 30 Abs. 3 Buchst. a
DORA 11	Kündigungsfristen und Berichtspflichten über Entwicklungen, die die Leistung beeinträchtigen könnten	DORA, Art. 30 Abs. 3 Buchst. b
DORA 12	Geprüfte Notfallpläne und IKT-Sicherheitsmaßnahmen nach dem Rahmen des Kunden	DORA, Art. 30 Abs. 3 Buchst. c
DORA 13	Teilnahme an den bedrohungsorientierten Penetrationstests des Kunden	DORA, Art. 30 Abs. 3 Buchst. d
DORA 14	Laufende Überwachung: uneingeschränkte Zugangs-, Inspektions- und Prüfrechte des Kunden und seiner Behörde	DORA, Art. 30 Abs. 3 Buchst. e
DORA 15	Ausstiegsstrategie: verpflichtender Übergangszeitraum und Unterstützung beim Wechsel	DORA, Art. 30 Abs. 3 Buchst. f

Erzeugt mit dem Sicherheitsnachweis-Toolkit von Scutoria aus den Antworten des Betriebs. Quellen am Original gelesen am 19. Oktober 2026: Richtlinie (EU) 2022/2555, Art. 21 Abs. 2 Buchst. d und Abs. 3; Durchführungsverordnung (EU) 2024/2690, Anhang, Nr. 5.1.4 und 5.2; Verordnung (EU) 2022/2554 (DORA), Art. 28 Abs. 8 und Art. 30 Abs. 1 bis 4; Verordnung (EU) 2016/679, Art. 28 Abs. 3. Erneut gelesen am 23. Oktober 2026: Richtlinie (EU) 2022/2555, Art. 21; Durchführungsverordnung (EU) 2024/2690, Art. 1 und Anhang, Nr. 5.1.4, 5.2 und 11.6.2; Verordnung (EU) 2022/2554, Art. 30. Die Ratschläge sind Auslegung. Keine Rechtsberatung.